

SOLSTREAK

BÁO CÁO KỸ THUẬT VÀ KIỂM TOÁN HIỆN TRẠNG

KẾT LUẬN KIỂM TOÁN

CHƯA đáp ứng đầy đủ toàn bộ lộ trình PDF. Phase 1-4 đã có nền tảng chạy được; Phase 5 Anchor chưa triển khai và một số gate tích hợp/production còn thiếu.

Thuộc tính	Giá trị
Tài liệu đối chiếu	SolStreak_lo_trinh_ky_thuat.pdf — 16 trang
Ngày kiểm toán	27/08/2026
Phạm vi	Ứng dụng web động, API backend, Privy, Jupiter Earn, Solana RPC, PostgreSQL, vòng quay, Anchor roadmap
Môi trường xác minh	Localhost/WSL để test model; chưa triển khai public web
Bằng chứng	7/7 unit tests pass; TypeScript pass; Next.js production build pass; 4 bảng Supabase tồn tại

Tài liệu này không chứa private key, seed phrase, database password hoặc API key.

1. Tóm tắt điều hành

SolStreak là ứng dụng tiết kiệm USDC dạng web động trên Solana. Người dùng đăng nhập bằng email/SMS qua Privy, sử dụng ví Solana embedded để ký giao dịch nạp/rút Jupiter Earn, duy trì chuỗi ngày tiết kiệm và nhận lượt quay thưởng do backend quyết định.

Kiểm toán cho thấy kiến trúc cốt lõi của Phase 1-4 đã được triển khai: frontend Next.js, ví Privy, transaction builder Jupiter, xác minh deposit on-chain, Postgres bền vững, streak có múi giờ Việt Nam và wheel có unique constraint. Tuy nhiên, dự án chưa thể được tuyên bố hoàn tất toàn bộ roadmap vì thiếu cron reconciliation, test tích hợp tiền thật, test ví mới/thiếu gas/blockhash timeout, hệ thống vận hành production và chương trình Anchor khóa kỳ hạn.

Mức sẵn sàng hiện tại

Sẵn sàng cho kiểm thử localhost có kiểm soát. Chưa sẵn sàng nhận tiền công chúng hoặc deploy Anchor/mainnet.

Nguyên tắc triển khai

- Bám sát thứ tự ba cửa kỹ thuật trong roadmap: Privy → Jupiter Earn → Anchor vault.
- Localhost chỉ dùng để kiểm thử model và tích hợp. Chỉ chuyển sang web động công khai khi các gate ổn định đã đạt.
- Mọi thay đổi ngoài roadmap phải được chủ dự án xét duyệt trước.
- Không gọi lợi suất là cố định; luôn ghi rõ ước tính, biến động theo thị trường và không được đảm bảo.

2. Hệ sinh thái và cơ sở hạ tầng

Thành phần	Vai trò	Hiện trạng
Next.js 16 + React 19	Web động, giao diện, API route và server-side logic	Build production đạt
Privy React SDK 3.38	OTP email/SMS, user session, Solana embedded wallet, identity token	Đã tích hợp; cần test OTP thực tế/domain
Solana / Agave RPC	Gửi, confirm và đọc transaction/versioned message	Helius mainnet đã cấu hình
Jupiter Earn SDK	Tạo instruction nạp/rút và đọc vị thế USDC	Đã tích hợp; chưa test hai chiều bằng khoản tiền nhỏ
Supabase PostgreSQL	Lưu users, deposits, streaks và spins	Đã migrate và xác minh đủ 4 bảng
Solana Explorer	Liên kết kiểm tra signature công khai	Đã cấu hình mainnet-beta
Anchor	Ổng heo khóa kỳ hạn và CPI Jupiter	Chưa triển khai theo đúng gate roadmap
Hosting web động	Cho phép người khác truy cập qua HTTPS/domain	Chưa thực hiện; chỉ localhost

Sơ đồ kiến trúc logic

Người dùng → Trình duyệt Next.js → Privy (OTP + ví) → Jupiter SDK → Helius RPC → Solana/Jupiter Earn
 Trình duyệt Next.js → API Route → Privy JWKS xác minh identity token → Supabase PostgreSQL
 API Route → Helius RPC đọc transaction → kiểm tra Jupiter program + USDC delta → cập nhật streak

Ranh giới tin cậy

- Frontend không được tự quyết định kết quả wheel hoặc tự cấp streak.
- Backend không tin wallet/signature trong JSON; wallet phải nằm trong identity token Privy đã ký.

- Backend đọc lại transaction từ RPC và chỉ ghi deposit khi giao dịch thành công, fee payer đúng, gọi đúng Jupiter Lending program và USDC của ví giảm.
- Private key không đi qua database hoặc backend SolStreak; việc ký diễn ra qua wallet Privy.

3. Ma trận đối chiếu yêu cầu trong PDF

Phase	Yêu cầu chính	Trạng thái	Bảng chứng/thiếu sót
0	VersionedTransaction; mainnet/devnet decision; gas do user trả; lỗi biến động	Một phần	VersionedTransaction và nhãn biến động đã có. Chưa thử devnet/local fork và giao dịch tiền thật nhỏ.
1	Privy email/SMS; embedded Solana wallet; ready/auth/wallet gate; sign thử message; bind user-wallet	Gần đủ	SDK, gate và identity-token binding đã có. Chưa có màn hình sign-message test và chưa ghi nhận test OTP thực tế.
2	Jupiter deposit/withdraw; blockhash muộn; decimals; vị thế/lãi; test ví mới/thiếu SOL	Một phần	Build/sign/send/confirm, decimals và đọc vị thế đã có. Chưa test mainnet hai chiều, timeout và ví mới.
3	Postgres; verify on-chain; replay-safe; streak 03:00 VN; cron reconciliation	Phần lớn	Schema, auth, verify, unique signature và grace window đã có. Thiếu cron và integration tests.
4	Wheel random backend; một lượt hợp lệ; client chỉ chạy animation	Phần lớn	Backend quyết định, DB unique mỗi ngày, eligibility thật. Thiếu fulfillment/collection UI và rate-limit tổng quát.
5	Anchor lock vault; Jupiter CPI; maturity/early withdrawal; cap; tests; audit	Chưa làm	Không có Anchor workspace/program/IDL/test. Đây là thiếu sót lớn nhất.
6	Ghép demo; Jupiter attribution; on-ramp mock; câu hỏi rủi ro/pháp lý	Một phần	Branding/disclaimer có. Chưa có on-ramp mock, public hosting, pháp lý và incident answer pack hoàn chỉnh.

Kết luận

Không đạt điều kiện 'đầy đủ toàn bộ PDF'. Có thể tiếp tục test Phase 1-4; không được bỏ qua Phase 2 gate để triển khai Anchor.

4. Cách hệ thống hoạt động

4.1 Đăng nhập và gắn ví

- Người dùng chọn đăng nhập email hoặc SMS trong giao diện Privy.
- Privy xác thực OTP và tạo/khôi phục Solana embedded wallet.
- Frontend chỉ cho phép thao tác khi ready, authenticated và wallet đều tồn tại.
- Khi gọi API, frontend gửi identity token. Backend xác minh chữ ký token qua Privy JWKS và kiểm tra wallet thuộc linked_accounts.
- Lần đầu, privy_user_id được bind với wallet_address trong bảng users; lần sau không được đổi sang ví khác tùy ý.

4.2 Nạp USDC vào Jupiter Earn

- Frontend đổi số USDC sang base units 6 chữ số thập phân bằng helper dùng chung.
- Jupiter Earn SDK tạo instruction deposit cho USDC mainnet.
- Ứng dụng lấy blockhash gần thời điểm ký, dựng VersionedTransaction và yêu cầu ví Privy ký.
- Frontend gửi raw transaction qua RPC, chờ confirmed và nhận signature.
- Frontend báo signature cho /api/streak/report cùng identity token.
- Backend đọc lại transaction, kiểm tra fee payer, trạng thái, Jupiter program và chênh lệch USDC; sau đó insert deposits và cập nhật streak trong transaction Postgres.

4.3 Rút USDC

- Jupiter SDK dựng instruction withdraw theo amount người dùng nhập.
- Ví Privy ký; frontend gửi và confirm qua RPC.
- Withdraw không tăng streak. Dashboard đọc underlyingAssets để hiển thị vị thế có thể quy đổi, gồm lợi suất biến động.

4.4 Streak

- Mỗi signature chỉ được ghi một lần vì là primary key.
- streakDay = thời gian block trừ 3 giờ rồi quy đổi theo Asia/Ho_Chi_Minh.
- Nạp nhiều lần cùng streakDay không tăng thêm ngày; ngày liên tiếp tăng current_streak; bị dứt thì bắt đầu lại từ 1.
- longest_streak giữ kỷ lục lớn nhất.

4.5 Lucky wheel

- API xác minh identity token và streak còn hiệu lực.
- Backend chọn prize theo trọng số; trọng số không nằm trong client bundle.
- Bảng spins có unique(wallet_address, spin_day), ngăn hai request đồng thời nhận hai lượt.
- Client chỉ nhận result rồi tính góc animation để kim dừng đúng ô.

5. Mô hình dữ liệu

Bảng	Khóa/ràng buộc	Mục đích
users	privy_user_id PK; wallet_address UNIQUE	Gắn một danh tính Privy với ví Solana đã xác minh
deposits	signature PK; FK wallet; amount > 0; streak_day index	Lưu deposit đã xác minh và chống replay
streaks	wallet_address PK/FK; current/longest >= 0	Trạng thái chuỗi ngày hiện tại và kỷ lục
spins	BIGSERIAL PK; UNIQUE wallet + spin_day	Lưu kết quả wheel bền vững và chống quay lặp

6. An toàn và kiểm soát rủi ro

Rủi ro	Kiểm soát hiện có	Còn thiếu
Giả mạo wallet	Privy identity token + linked Solana wallet	Test token hết hạn/rotation/JWKS outage
Replay signature	deposits.signature là primary key	Load/concurrency integration test
Bảo giao dịch không phải deposit	Fee payer + Jupiter program + USDC decrease	Kiểm tra discriminator/expected accounts sâu hơn
Wheel gian lận	Random ở backend + unique DB	CSPRNG/audit log nếu phần thưởng có giá trị
RPC rate limit/outage	RPC riêng, lỗi được trả về API	Retry policy, multi-RPC failover, monitoring
Lộ secret	.env.local bị gitignore	Rotate các secret đã chia sẻ; secret manager trên hosting
Lợi suất thiếu hụt	UI ghi rõ biến động, không đảm bảo	Treasury policy; không cam kết fixed tier
Anchor mất tiền	Chưa deploy khi chưa test/audit	Program tests, cap, fork, audit độc lập

7. Bảng chứng kiểm thử tại thời điểm báo cáo

Hạng mục	Kết quả	Phạm vi
Unit tests	PASS — 3 files, 7 tests	USDC decimals; grace 03:00; streak duplicate/consecutive/reset; wheel weights/boundaries
TypeScript	PASS	npm tsc --noEmit
Production build	PASS	Next.js 16.3.3; static pages + 3 dynamic API routes
Database	PASS	Supabase có users, deposits, streaks, spins
Privy OTP	CHƯA CÓ BẢNG CHỨNG	Cần test thủ công email/SMS và domain localhost
Jupiter mainnet E2E	CHƯA TEST	Cần SOL gas + USDC rất nhỏ; deposit rồi withdraw
Cron reconciliation	KHÔNG TỒN TẠI	Chưa có endpoint/job và test
Anchor	KHÔNG TỒN TẠI	Chưa có program, IDL, local validator test hoặc audit

Cảnh báo build bigint-buffer chuyển sang pure JavaScript không làm build thất bại, nhưng dependency audit vẫn còn advisory bắc cầu từ hệ Solana/Jupiter/Privy. Không dùng npm audit fix --force vì có thể hạ/bê API; cần theo dõi upstream và đánh giá từng advisory trước production.

8. Thiếu sót và hạng mục cần bổ sung

Ưu tiên	Hạng mục	Điều kiện hoàn thành
P0	Test Privy → Jupiter hai chiều	OTP, ví mới, ký, deposit USDC nhỏ, position tăng, withdraw hết, Explorer xác nhận
P0	Cron reconciliation	Quét transaction định kỳ; idempotent; secret cron; phục hồi report bị bỏ lỡ
P0	Integration tests	Postgres test DB + RPC fixtures; auth giả mạo; replay; concurrency spin; RPC failure
P0	Secret rotation	Đổi DB password và RPC key đã từng chia sẻ; cấu hình secret manager/domain restriction
P1	Transaction recovery UX	Giao dịch thành công nhưng report lỗi có nút retry, không yêu cầu nạp lại
P1	RPC resilience	Timeout, retry có backoff, failover provider, metrics và alert
P1	Reward fulfillment	Định nghĩa badge/discount/jackpot; collection UI; ledger/audit; treasury nếu có tiền
P1	Rate limiting	Giới hạn auth user/IP cho status/report/spin; chống RPC/database abuse
P1	Dynamic hosting	HTTPS, domain, env secrets, migrations, health check, logs, backups, rollback
P2	On-ramp mock	UI minh họa được gắn nhãn coming soon đúng Phase 6
P2	Anchor vault	Chỉ khởi động sau P0 E2E; CPI spike; cap; time tests; treasury policy; audit
P2	Pháp lý và incident plan	Rà soát pháp lý Việt Nam; câu trả lời khi Jupiter/RPC/DB gặp sự cố

9. Kế hoạch chuyển từ localhost sang web động

Không triển khai public ngay ở trạng thái hiện tại. Lộ trình chuyển đổi đề xuất sau khi chủ dự án phê duyệt từng gate:

Gate	Nội dung	Tiêu chí duyệt
A — Local functional	Privy login, dashboard DB, Jupiter read	Không lỗi auth/database; dữ liệu đúng ví
B — Mainnet micro test	Deposit/withdraw khoản rất nhỏ	Hai chiều thành công; streak đúng; không mất tiền
C — Reliability	Cron, retry, rate limit, monitoring	Test failure/replay/concurrency đạt
D — Security	Rotate secret, dependency review, threat review	Không còn secret lộ; risk acceptance được ký
E — Staging web	Hosting động + HTTPS + domain test	Privy allowed origin, Supabase/RPC policy, logs và rollback
F — Public demo	Cho người khác truy cập	Giới hạn tiền/rủi ro; disclaimer; support/incident owner

Hạ tầng web động dự kiến

- Next.js Node runtime trên nền tảng hỗ trợ dynamic API routes và outbound TCP tới Postgres.
- Supabase Session/Transaction pooler phù hợp mô hình hosting; giới hạn connection pool phải được kiểm tra theo nền tảng.
- Biến NEXT_PUBLIC chỉ dành cho dữ liệu có thể lộ ở browser. DATABASE_URL và server RPC secret chỉ đặt trong secret manager.
- Migration chạy như bước phát hành có kiểm soát; backup trước thay đổi schema và có rollback plan.
- Health check, structured logs, error tracking, RPC latency/error rate, DB connection usage và cron result cần được giám sát.

10. Quyết định về Anchor vault

CHƯA TRIỂN KHAI

Đây là quyết định an toàn và phù hợp thứ tự roadmap, không phải lỗi bỏ sót vô tình. Không nên scaffold/deploy chương trình nhận tiền khi luồng Jupiter E2E chưa được xác nhận.

- Cần cài Rust/Anchor và ghim version tương thích Solana/Agave.
- Bắt đầu bằng một CPI spike gọi Jupiter trên mainnet fork/local fixture, không bắt đầu từ full vault.
- Seed position phải có nonce/counter để một owner mở nhiều vị trí.
- Phép tính lãi dùng checked u128; test maturity ± 1 giây, overflow, early withdrawal và protocol shortfall.
- Có cap amount on-chain, pause/emergency path, authority/treasury policy và audit độc lập trước mainnet.

11. Kết luận và đề xuất quyết định

SolStreak đã vượt qua mức mock UI ban đầu và có kiến trúc backend hợp lý cho streak/wheel. Các kiểm soát quan trọng — identity token, on-chain verification, replay-safe signature, grace window và persistence — đã hiện diện. Dù vậy, sản phẩm chưa hoàn tất toàn bộ tài liệu kỹ thuật và chưa được phép nhận tiền công chúng.

Đề xuất

Duyệt tiếp giai đoạn kiểm thử localhost Phase 1-4. Không duyệt public launch hoặc Anchor mainnet ở thời điểm báo cáo.

Thứ tự hành động tiếp theo

- 1. Test đăng nhập Privy và bind đúng ví trên localhost.
- 2. Test Jupiter deposit/withdraw khoản rất nhỏ với tài khoản riêng cho demo.
- 3. Bổ sung cron reconciliation và integration test suite.
- 4. Rotate toàn bộ credential đã từng xuất hiện trong trao đổi.
- 5. Sau khi các gate đạt, dựng staging web động; chỉ public khi có monitoring/rollback.
- 6. Cuối cùng mới phê duyệt prototype Anchor CPI theo Phase 5.

— Hết báo cáo —